

0基础入门CTF

入门前须知

关于入门需要的能力

CTF 是什么

flag 在哪

- 1、web
- 2、逆向 (reverse)
- 3、PWN
- 4、密码学 (crypto)
- 5、杂项 (misc)
- 6、开源情报 (osint)
- 7、取证 (forensic)

关于方向选择

方向结合实际

- 1、web
- 2、pwn
- 3、逆向-re
- 4、密码学
- 5、杂项—misc
- 6、osint 和 forensic

推荐的网站：

刷题平台：

推荐的笔记记录软件：

写在后面

入门 CTF 前请先阅读《中华人民共和国网络安全法》！！！做一个白帽子，不要用技术来作恶，出了事不要说是我教的，谢谢！

入门前须知

栽一棵树最好的时间最好是十年前，其次是现在。既然选择了要入门 CTF，那希望这份文档可以帮助你跨过门槛，而不用在门口徘徊！

关于入门需要的能力

只要拥有自学能力，善用搜索引擎和 AI。可以交流，但没有人会手把手教，遇到不会的可以先问百度/谷歌/ai（搜索的时候尽量学会提取关键字然后空格隔关键字来搜索，谷歌可以了解一下 hack 语法）。所有的知识都能在网上找到，没必要买课，书籍等入门之后根据感兴趣方向自行购买（也可以不买，看个人选择）

CTF 是什么

CTF (Capture The Flag) 中文一般译作夺旗赛，在网络安全领域中指的是网络安全技术人员之间进行技术竞技的一种比赛形式。

讲人话就是：这是一群人办的比赛，比赛规则就是做题拿分，如何拿分——解出题目后会看到一个 flag（也就是夺旗赛的由来），比如这样一串东西：flag{this_is_flag}。

至于具体的赛题分类，大概有以下几种：

- 1、黑网站 (Web)
- 2、破解软件 (Reverse 即逆向)
- 3、攻击应用服务 (PWN)
- 4、破解密码 (Crypto 即密码学)
- 5、找到隐藏在文件里的信息 (MISC 即杂项)
- 6、找信息 (OSINT 即开源情报)
- 7、分析数据 (Forensic 即数字取证)

大致的赛题分类就这些，当然有些比赛不一定每种类型都有，也有上述没提到的分类，但这不重要，这已经包含大部分的比赛分类的了。

flag 在哪

既然已经知道目标是拿到 flag，那么 flag 在哪，每种类型举个简单例子

1、web

WEB 类的题目包括但不限于：SQL 注入、XSS 跨站脚本、CSRF 跨站请求伪造、文件上传、文件包含、框架安全、PHP 常见漏洞、代码审计等。

flag 可能是藏在服务器根目录或 web 目录下的文件里（可能是 flag 或 flag.php 或者 flag.txt）或者数据库里，你黑进网站后，去读这个文件，或通过数据库注入读数据库内容。也有的题可能本来就不会让

你黑进去，只是给你一段源码让你绕过他的防御，就会给你打印出 flag。

比如某道 web 题，先启动容器（就是一个 ip 地址），跳转后发现页面如下

```
<?php
highlight_file(__FILE__);

function scan($directory){
    return var_dump(scandir($directory));
}

function read($f){
    echo file_get_contents($f);
}

call_user_func($_GET['a'], $_GET['b']);
?>
```

Warning: call_user_func() expects parameter 1 to be a valid callback, no array or string given in /var/www/html/index.php on line 12

这是一段php代码，给出一个warning提示：在/var/www/html/index.php文件的第12行，call_user_func()函数期望收到一个有效的回调函数参数，但实际上没有传递有效的参数。观察代码，可以利用三个函数scan()、read()、call_user_func()，通过构造url尝试获取flag。

🔄 不安全 | 106.15.186.69:8097/?a=read&b=/flag

```
<?php
highlight_file(__FILE__);

function scan($directory){
    return var_dump(scandir($directory));
}

function read($f){
    echo file_get_contents($f);
}

call_user_func($_GET['a'], $_GET['b']);
?> flag{19a0664d0b3d997318f6e4940240e91c}
```

（这里不介绍解题思路，学得多了就有思路了）

2、逆向 (reverse)

对于逆向，题目会给你一个软件，你要用反编译工具（IDA）去打开它，然后读反编译出来的代码，理解代码运行过程来推导出 flag。也有的题用动态调试来运行这个软件，去读或改它的内存（类似游戏修改器，比如外挂）或修改他的运行方式来获得 flag（比如玩游戏直接调到最后一关）。

（推荐题目 bugku——入门逆向）

3、PWN

对于 PWN，PWN 其实和 Web 有点像，不过 PWN 攻击的不是 Web 服务，而是其它的软件漏洞，一般的题目会给你一个软件（和部署在服务器上的软件是一样的）以及一个 ip 和端口（就是那个软件所在端口），然后你去逆向分析这个软件（比逆向题简单），找到漏洞，然后去攻击服务器上的软件，从而得到服务器权限，然后去读 flag 文件内容。

（推荐题目 bugku——瑞士军刀）

4、密码学 (crypto)

对于密码学，很简单，他给你密文，你解密出来就是 flag 了。当然密文并不是题目直接告诉你，一般都会隐晦，要猜和尝试，密码也可能套了很多层。

5、杂项 (misc)

对于杂项，杂项大部分是隐写题或流量审计，你的目的就是在他给你的文件里找 flag，当然 flag 并不是那么好找的，有的是文本形式藏起来，有的是图片形式，甚至有给你一段音乐他的频谱图就是画着 flag 的。题目真的很杂，也知道为啥叫杂项了吧.....

比如题目附件给你半张图，此时可以猜到是图片长度或宽度被隐藏了，通过改变图片长宽显示出完整图片，即可得到 flag。

6、开源情报 (osint)

这种题目在 ctf 刷题平台并不是常见，但是有的比赛也会有。形式就是给你一张图片或其他形式的文件，让你根据这个图片/文件，定位到具体位置，简单来说就是获得情报。

比如直接给你一张摩天轮的图片，需要你根据图片里面的信息（可能是穿着、地面、树木等等），猜到是哪里的摩天轮，一般 flag 形式为 flag{城市 _ 游乐场 _ 设施名}（这是举的例子，实际情况看题目要求）

7、取证 (forensic)

有的比赛不单把取证份出来，而是放到杂项 misc 里，问题不大，思路是差不多的。取证通常是需要从系统镜像、配置文件等等提取关键信息（如用户名、密码、题目要求的信息等），再进行解密得到 flag（有可能直接就能看到 flag，有可能需要解密）。常见题目有 win 系统取证、网络流量分析等。

关于方向选择

看到这对几种方向应该有一个粗略的了解，一般来说选一种（web/pwn/re）作为主业，misc/crypto/osint/forensic 里面选两个做副业。不建议全选，除非你是超人。当然你如果热爱数学，专攻 crypto 也是 ok 的

方向结合实际

网络安全下的分支也挺多，CTF 只是其中一种

1、web

渗透测试，就是挖别人网站的漏洞（没有授权不要挖，容易被帽子叔叔请去喝茶），这也是一个工作方向（安全服务工程师）

2、pwn

PWN 通常指通过漏洞利用、社会工程学攻击等手段，成功获得设备、系统或网络的未授权控制权。挖 Web 以外应用的漏洞，还有系统的漏洞。常见的安卓 root 和苹果越狱就是 PWN 相关的，实际上这两个都是获取系统的最高权限(简称提权)。还有游戏外挂计算机病毒之类的也是和 PWN 有关的。

3、逆向-re

平常用的破解版软件就是逆向搞出来的，有些游戏外挂也是。

4、密码学

字面意思

5、杂项—misc

隐写经常用作知识产权的保护

6、osint 和 forensic

偏向政府公安类的打击黑灰产较多

推荐的网站：

 AI时代：在正式开始之前 – Hello CTF

 CTF+ | CTF学习与交流平台

刷题平台：

bugku

ctfshow

攻防世界

推荐的笔记记录软件：

语雀

typora

obsidian

写在后面

很高兴有很多人期待我的文档，先谢谢各位。

当你第一次打开终端，面对一道完全看不懂的题目，花了一整个下午只拿到一个 flag 的时候——请记住，每一个你羡慕的别人，都曾经和你坐在同样的位置，经历过同样的茫然。

CTF 的魅力从来不在于你能多快解出一道题，而在于你愿意在"完全不会"和"好像有点思路了"之间反复徘徊，还不放弃。那种盯着屏幕几个小时后突然灵光一闪的瞬间，那种提交 flag 后看到 "Correct!" 时心跳加速的感觉，是任何教科书都给不了你的东西。，解出 flag 后真的很爽，可能解出来后你会吐槽出题人，可能会觉得这道题出的很厉害，这都是你能从 CTF 中获得的。

最后，感谢你愿意翻开这份入门指南，愿意花时间走进 CTF 的世界。能把这些内容整理出来，本身也是我自己学习和成长的过程，如果其中哪怕有一个知识点帮到了你，对我来说就已经足够了。祝你在 CTF 的路上，永远保持好奇，享受每一次破解的快乐。

谢谢！